c2blue55 — détection en temps réel du command-and-control DNS, avec preuves observables

Candidature au concours Hackers-Arise · résumé exécutif · hazyhaar lab · 2026-11-06

Vidéo (muette, 5 min 48 s, sous-titrée en anglais) :
https://github.com/hazyhaar/c2blue55/blob/main/hackers-arise-2026/c2blue55-demo-en-v2.mp4

Dépôt du moteur de détection (MIT) : https://github.com/hazyhaar/c2blue55 — contient le banc comparatif de 7 piles open source de sécurité DNS (`docs/dns_detection_solutions_benchmark.fr.md`)

Kit de démonstration (tableau de bord `c2blue-dns-live`, scripts de rejeu, les 20 captures réelles) :
https://github.com/hazyhaar/c2blue55/tree/main/hackers-arise-2026

Le générateur rouge (redbench) et le script de scénario qui le pilote ne sont pas publiés : les chiffres de matrice, de flux mixte et de charge ci-dessous proviennent de ce générateur privé et sont documentés dans les fichiers de preuve ; le rejeu des captures réelles et le tableau de bord sont entièrement reproductibles à partir du code public.

1. Ce qu'est la candidature

c2blue55 est un moteur de détection en Go 1.27 des tunnels DNS et du command-and-control (C2). Dans cette candidature il tourne sous la forme de `c2blue-dns-live` : un écouteur UDP qui classe chaque datagramme reçu, y répond, et affiche le verdict dans un tableau de bord avec la raison, les seuils qui ont déclenché, les gardes bénignes évaluées et le SHA-256 du datagramme. **redbench** est le côté rouge : un générateur qui ouvre une vraie socket UDP, enregistre son IP:port source auprès de c2blue55, puis émet soit du bruit DNS légitime, soit l'un de 19 motifs hostiles. **po2po** est le front office qui présente les deux côtés.

La règle directrice : le générateur décrit ce qu'il envoie, mais **c2blue55 ne juge que les octets qu'il reçoit**. L'identifiant de campagne (`run_id`) circule dans le plan de contrôle HTTP, jamais dans un nom de requête, et ne devient jamais un critère de détection. Deux contrôles permanents le prouvent : une requête bénigne envoyée sous une campagne hostile reste bénigne, et des labels allongés envoyés sous une campagne bénigne alertent.

Tout ce qui suit a été exécuté les 5 et 6 novembre 2026 dans un laboratoire local et enregistré en direct ; les attentes ont été raccourcies dans la vidéo, rien n'a été réordonné ni retapé. Aucun déploiement public n'est revendiqué.

2. Résultats en un coup d'œil

Élément	Résultat réellement exécuté
Outils offensifs réels	7 outils (dnstt, iodine, dns2tcp, Slipstream, VayDNS, NoizDNS, Soar), 18 captures fraîches enregistrées par tcpdump sur un maillage privé, **18/18 détectées** au rejeu hors ligne par le même classifieur ; transferts applicatifs prouvés (ressource HTTP de 35 149 octets au SHA-256 identique aux deux bouts pour dnstt et dns2tcp, trois échos ICMP de 1 024 octets pour iodine).
Contrôle négatif	200 vraies requêtes et 200 réponses NOERROR réparties sur 200 apex distincts : **0 alerte sur 400 observations**. Les mêmes 400 observations sur un seul apex : 136 alertes de rafale (M-03). Le débit brut seul n'est pas traité comme une preuve de C2.
Matrice fonctionnelle	**26/26** : 7 familles de trafic légitime sans alerte, 19 motifs hostiles chacun apparié à son code de raison attendu ; première alerte entre 0 ms et 145 ms après la première question.
Flux mixte	1 000 requêtes dans un même run, 80 % de bruit légitime et 20 % de labels allongés : 800 classées bénignes, 200 classées M-01, **0 alerte sur la part bénigne**.
Charge soutenue	10 000 QPS configurés pendant 5 s : 48 783 envoyés, 48 783 reçus, 0 perdu, 0 alerte C2, 81 % d'un cœur.
Saturation	45 000 QPS configurés pendant 5 s : 205 771 envoyés, 102 232 reçus, **103 539 pertes comptées et affichées**, 0 alerte C2, 97 % d'un cœur.
Preuves	Par run : événements JSONL avec SHA-256 par datagramme, PCAP reconstitué, manifeste à politique de rétention intégrale ; fichiers en mode 0600.
Vérification logicielle	Suites de tests sous détecteur de course : 41 tests sur les paquets du tableau de bord, 80 sur le générateur et le front office, 0 échec (count=3 lors de la campagne précédente : 123 et 240 actions pass).

3. Comment un verdict s'explique

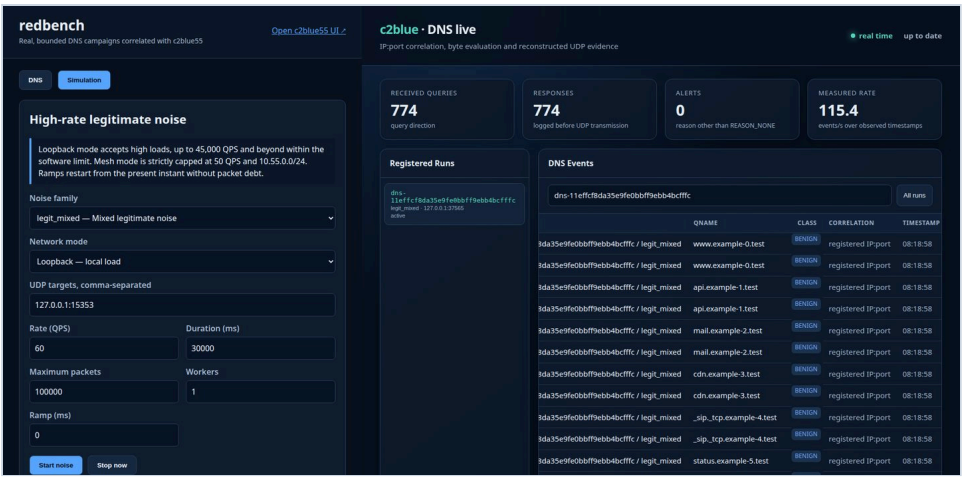


Figure 1 — À gauche : redbench émet du bruit légitime mixte à 60 QPS depuis une socket enregistrée. À droite : c2blue55 filtré sur le même `run_id` ; requêtes et réponses portent l'IP:port source réel, les alertes restent à 0.

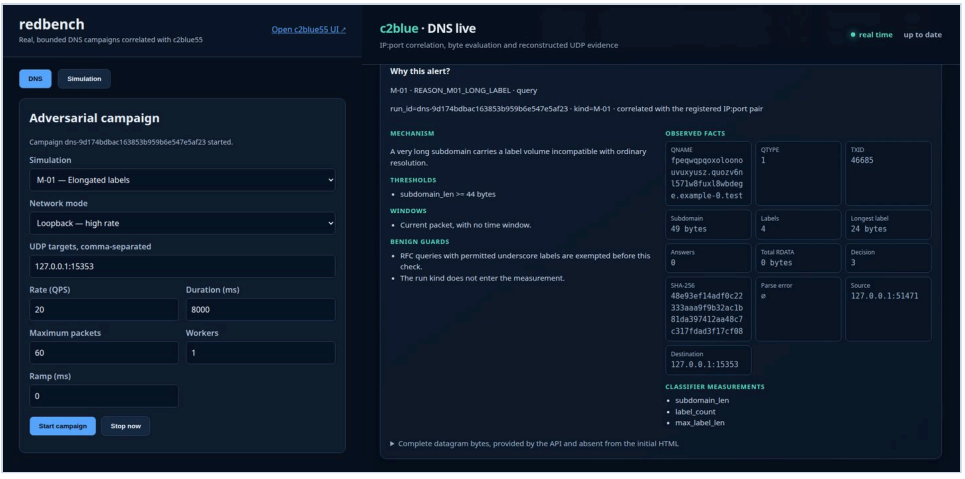


Figure 2 — « Why this alert » pour une requête M-01 : mécanisme, seuil réel (sous-domaine ≥ 44 octets), fenêtre, gardes bénignes (labels RFC à tiret bas exemptés ; le type de run n'entre jamais dans la mesure), faits observés, SHA-256 du datagramme, et les octets complets à la demande.

4. Preuves issues d'outils offensifs réels

Sept vrais outils de tunnel DNS ont tourné entre deux hôtes d'un maillage WireGuard privé, sans aucune cible externe. Chaque capture a été enregistrée indépendamment par tcpdump côté serveur, puis rejouée hors ligne par `c2agent replay`. Les empreintes des fichiers de capture correspondent au résumé du banc ; les tentatives échouées (relais HTTP d'iodine, multipath Slipstream sans identifiant de connexion commun) sont conservées dans les preuves plutôt que retirées au montage.

Outil	Runs	Observations	Raisons observées au rejeu frais
dns2tcp	1	282	P1 exfiltration descendante 271, M-01 label long 4, P15 renouvellement RDATA 1
dnstt	1	196	P1 139, M-01 22, M-02 entropie élevée 22, P15 5
iodine	1	240	M-01 60, P1 7, M-02 2
NoizDNS	4	316	M-01 144, M-02 72, P1 24, P15 11
Slipstream	3	396	M-01 324, P15 47, P1 25
Soar	2	194	P1 92, M-01 39, P15 39, M-02 15, P14 charge utile dans réponse NXDOMAIN 2
VayDNS	6	1 292	M-01 360, P1 301, P15 178, P7 C2 par SRV 98
Bénin, réparti	1	400	aucune (200 apex, vraies requêtes `dig`, aucun seuil modifié)
Bénin, apex unique	1	400	M-03 rafale haute fréquence 136

5. Des critères plutôt que des étiquettes

Le tableau reflète les contrôles réellement appliqués par le classifieur ; le tableau de bord affiche les valeurs mesurées à côté de chaque verdict. Les mesures internes non exportées sont identifiées comme telles et ne reçoivent jamais de valeur inventée.

Motif	Mesure et seuil appliqués	Garde ou fenêtre
M-01	Longueur de sous-domaine ≥ 44 octets.	Paquet courant ; type de run ignoré.
M-02	Premier label ≥ 20 octets, entropie ≥ 4,10 bits/octet, cardinalité > 16.	P2, P12 et M-01 évalués d'abord.
M-03	Au moins 15 requêtes vers un apex en ≤ 2 secondes.	Réponses exclues ; pipeline par run.
M-04	Suite de consonnes ≥ 5, RCODE = 3, au moins 4 QNAME distincts.	Au plus 16 empreintes.
P1	RDATA ≥ 180 octets en TXT/NULL, ou ratio > 2 et entropie > 4.	Préfixes TXT RFC exemptés.
P3	Au moins 5 QTYPE, CV < 0,12, entropie de Markov > 0,40.	8 requêtes ; fusion A/AAAA ≤ 50 ms.
P4	Sous-domaine de 10 à 32 octets sur au moins 4 parents.	Point, tiret et tiret bas exclus.
P20 / P21	3 empreintes SOA distinctes / 8 identifiants d'interface IPv6 pleine largeur distincts.	Fenêtres de 10 minutes / 600 secondes.

6. Reproduire

```
# Go 1.27 avec GOEXPERIMENT=simd
go build -o bin/c2blue-dns-live ./cmd/c2blue-dns-live
go build -o bin/c2agent ./cmd/c2agent
(umask 077; head -c 32 /dev/urandom | base64 | tr -d '/+=\n' > ui-token)
export C2BLUE_DASHBOARD_TOKEN="$(cat ui-token)"
bin/c2blue-dns-live -udp-listen 127.0.0.1:15353 -http-listen 127.0.0.1:4256 -evidence-dir evidence &
# rejeu hors ligne des 20 captures réelles par le même classifieur, avec contrôle des empreintes
python3 replay-benchmark.py captures replay
# ou n'importe quelle capture seule
bin/c2agent replay --pcap captures/dnstt-clear.pcap --out-root replay --dns-ports 53
# preuve d'un run du tableau de bord : manifeste, événements JSONL avec SHA-256 par datagramme, PCAP reconstitué
curl -s -u evaluator:"$(cat ui-token)" http://127.0.0.1:4256/api/v1/evidence/<run_id>
```

Le tableau de bord tourne sur loopback, protégé par jeton ; rien n'a besoin d'être exposé. Tout client DNS pointé sur l'écouteur (par exemple `dig @127.0.0.1 -p 15353`) apparaît dans le tableau de bord avec son verdict. La matrice de 26 cas, le flux mixte et les étapes de charge ont été pilotés par le générateur privé à travers les deux API HTTP ; leurs rapports (`full-report.json`, `load-10k.json`, `load-45k.json`) sont des synthèses pilotées par API, pas des mesures indépendantes. Le rejeu hors ligne des captures noyau est la mesure indépendante, et c'est la partie qu'un tiers peut refaire intégralement.

7. Les limites qui restent visibles

- **Périmètre de la matrice synthétique :** M-01..M-04, P1..P13, P20, P21. P14 et P15 ne sont exercés que par les captures réelles (Soar, dnstt, VayDNS…), pas par le générateur.
- **Modes de capture :** le PCAP du tableau de bord est une reconstitution Ethernet/IP/UDP des datagrammes traités (champ de manifeste `capture_mode = udp-reconstructed`) ; seuls les PCAP du banc sont des captures noyau.
- **Saturation :** à 45 000 QPS configurés, le chemin monocœur ne répond plus à toutes les requêtes ; les pertes sont comptées, la fenêtre mémoire évince les anciens événements (compteur exposé), les preuves sur disque ne sont pas réduites.
- **Réseau :** partie interactive sur loopback IPv4 ; captures d'outils issues d'un maillage privé ; aucune cible publique, aucun déploiement public. Un accès évaluateur distant exigerait TLS et une gestion des secrets.
- **Frontières ouvertes connues :** multipath Slipstream sur plusieurs résolveurs, échanges NoizDNS courts, tunnel multiplexé dans une connexion HTTP/3 partagée. Une base de normalité sur journaux d'hôte existe mais ne généralise pas encore (son jour froid de validation signale chaque événement) et ne fait pas partie de cette candidature.
- **Auto-audit :** le banc comparatif du dépôt applique le même standard à c2blue55 et documente ses propres frontières de faux positifs (zones étrangères non calibrées, navigation multi-domaines) à côté de 24 divulgations aux six autres piles, dont 20 sous forme d'issues GitHub publiques.

Lexique

run_id — identifiant de campagne échangé par HTTP, jamais dans le DNS. **M-xx / Pxx** — familles de motifs : M = mesures lexicales ou de rafale sur des paquets isolés ou de courtes fenêtres, P = règles de grammaire protocolaire avec état. **Code de raison** — l'unique règle nommée qui a déclenché, par exemple `REASON_M01_LONG_LABEL` ; `REASON_NONE` signifie bénin. **Manifeste de preuve** — JSON listant le JSONL et le PCAP d'un run et sa politique de rétention. **c2agent replay** — exécution hors ligne du classifieur sur un PCAP, produisant observations, états et un manifeste signé. **Apex** — le domaine parent enregistrable sous lequel les sous-domaines sont comptés.